

# TORKIS

## Jak aplikace komunikuje s Firebase a Google Cloud

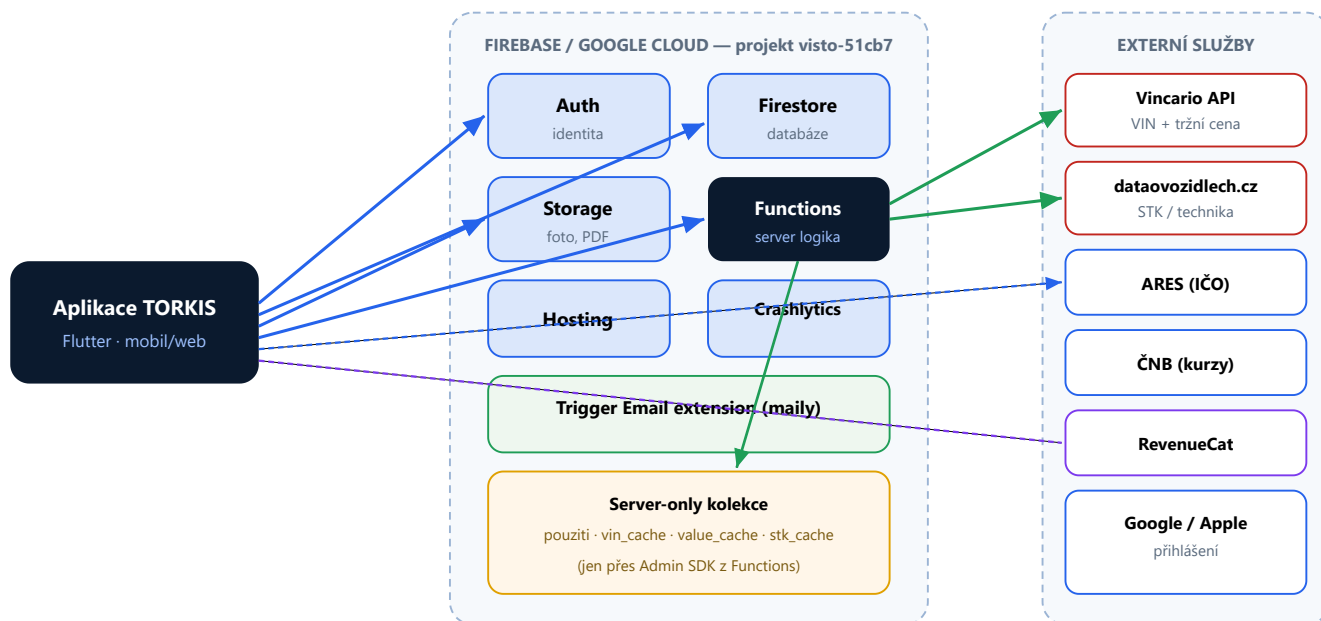
Verze aplikace 5.3.2 · Stav k 6. 6. 2026 · Projekt Firebase `visto-51cb7` · Region funkcí `eu-west3`

Tento dokument popisuje, s jakými službami aplikace TORKIS komunikuje, jaká data z nich **čte**, jaká do nich **zapisuje**, kudy tečou citlivé klíče a jak je vše zabezpečené. Je psaný tak, aby byl srozumitelný i bez znalosti zdrojového kódu.

**Legenda značek u dat:** **ČTE** aplikace čte **ZAPISUJE** aplikace zapisuje **ČTE+ZAPISUJE** přístup jen ze serveru (Cloud Functions)

## 1. Přehled architektury

Aplikace je klient (Flutter — Android, iOS, web/Windows) a sama o sobě **neukládá žádná byznys data lokálně natrvalo** kromě drobných uživatelských preferencí. Veškerá data žijí v cloudu Google/Firebase. Drahá a citlivá volání (placená VIN API) nejdou z aplikace přímo, ale přes **Cloud Functions**, které jediné drží tajné klíče.



Obr. 1 — Aplikace mluví hlavně s Firebase. Placená VIN/STK API a tajné klíče jsou schované za Cloud Functions; jen ARES, ČNB a přihlašovací poskytovatelé jdou z klienta přímo.

## 2. Firebase projekt a platformy

| Položka | Hodnota |
|---------|---------|
|---------|---------|

|                        |                                                                                            |
|------------------------|--------------------------------------------------------------------------------------------|
| ID projektu            | visto-51cb7                                                                                |
| Platformy              | Android, iOS, web, Windows, macOS (konfigurace v <code>lib/firebase_options.dart</code> )  |
| Region Cloud Functions | europa-west3 (Frankfurt)                                                                   |
| Hosting                | web build ( <code>build/web</code> ) + zákaznický portál na cestě <code>/zakazka/**</code> |

### 3. Použité služby Firebase

| Služba                           | K čemu slouží v TORKIS                                                                                      |
|----------------------------------|-------------------------------------------------------------------------------------------------------------|
| <b>Authentication</b>            | Identita uživatele. Metody: e-mail+heslo, Google, Apple a <b>anonymní</b> přihlášení pro zákaznický portál. |
| <b>Cloud Firestore</b>           | Hlavní databáze — všechna byznys data (zakázky, vozidla, zákazníci, ceník, nastavení, předplatné...).       |
| <b>Cloud Storage</b>             | Binární soubory — fotky z příjmu, schéma poškození, vygenerované PDF protokoly, podpis.                     |
| <b>Cloud Functions</b>           | Serverový kód — placená VIN/STK API, webhook plateb, mazání účtů. Drží tajné klíče.                         |
| <b>Crashlytics</b>               | Hlášení pádů a fatálních chyb (mimo web). Odesílá technická data o pádu, ne byznys obsah.                   |
| <b>Hosting</b>                   | Webová verze aplikace + veřejná stránka zákaznického portálu ( <code>zakazka.html</code> ).                 |
| <b>Trigger Email (extension)</b> | Rozšíření, které z dokumentů v kolekci <code>maily</code> rozesílá e-maily zákazníkům.                      |

## 4. Datový model — kolekce Firestore

Každý záznam servisu nese pole `servis_id`. Pravidla zajišťují, že uživatel vidí **jen data svého servisu** (viz kap. 8). Níže je přehled, co aplikace z jednotlivých kolekcí čte a co do nich zapisuje.

| Kolekce                                  | Obsah                                                                                                                                               | Přístup aplikace                              |
|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------|
| <code>uzivatele</code>                   | Profil uživatele: uid, e-mail, jméno, role (admin/zaměstnanec), <code>servis_id</code> , oprávnění modulů ( <code>prava</code> ), osobní nastavení. | <b>ČTE+ZAPISUJE</b> smazání člena přes funkci |
| <code>nastaveni_servisu</code>           | Firemní nastavení: název, IČO/DIČ, adresa, formát čísla zakázky, typy záznamu, přepínače (podpis, SPZ, auto-číslo).                                 | <b>ČTE+ZAPISUJE</b>                           |
| <code>predplatne</code>                  | Plán (basic/standard/pro/trial) a platnost. Určuje serverové limity.                                                                                | <b>ČTE</b> zápis jen „trial“ / server         |
| <code>zakazky</code>                     | Protokoly příjmu vozidla: zákazník, vozidlo, stav vozu, požadované úkony, odkazy na fotky a PDF, podpis, <code>portal_token</code> .                | <b>ČTE+ZAPISUJE</b>                           |
| <code>zakazky/.../zakaznik_zpravy</code> | Komunikace servis ↔ zákazník přes portál, schvalování nacenění.                                                                                     | <b>ČTE+ZAPISUJE</b>                           |
| <code>vozidla</code>                     | Kartotéka vozidel servisu (SPZ, VIN, značka, technika, historie návštěv).                                                                           | <b>ČTE+ZAPISUJE</b>                           |
| <code>zakaznici</code>                   | Kartotéka zákazníků (jméno, kontakt, IČO/DIČ, adresa).                                                                                              | <b>ČTE+ZAPISUJE</b>                           |
| <code>ukony</code>                       | Ceník prací/úkonů (název, cena, čas, kategorie).                                                                                                    | <b>ČTE+ZAPISUJE</b>                           |
| <code>faktury</code>                     | Vystavené faktury (číslování, položky).                                                                                                             | <b>ČTE+ZAPISUJE</b>                           |
| <code>vin_skeny</code>                   | Historie VIN dekodů uložená v kartotéce servisu.                                                                                                    | <b>ČTE+ZAPISUJE</b>                           |
| <code>value_skeny</code>                 | Historie zjištění tržní hodnoty.                                                                                                                    | <b>ČTE+ZAPISUJE</b>                           |
| <code>znacka</code>                      | Sdílená referenční loga značek vozidel.                                                                                                             | <b>ČTE</b> zápis jen vlastník                 |
| <code>maily</code>                       | Fronta odchozích e-mailů pro Trigger Email extension.                                                                                               | <b>ZAPISUJE</b> založení e-mailu              |
| <code>chybove_logy</code>                | Aplikační chybové logy.                                                                                                                             | <b>ZAPISUJE</b> čte jen vlastník              |

### Server-only kolekce (aplikace na ně nesmí)

| Kolekce                  | Obsah                                                        | Přístup            |
|--------------------------|--------------------------------------------------------------|--------------------|
| <code>pouziti</code>     | Měsíční počítadla spotřeby placených API (limity dle plánu). | <b>SERVER-ONLY</b> |
| <code>vin_cache</code>   | Mezipaměť výsledků VIN dekódu (šetří placená volání).        | <b>SERVER-ONLY</b> |
| <code>value_cache</code> | Mezipaměť tržních hodnot.                                    | <b>SERVER-ONLY</b> |
| <code>stk_cache</code>   | Mezipaměť STK dat (platnost 24 hodin).                       | <b>SERVER-ONLY</b> |

## 5. Cloud Storage — binární soubory

---

Soubory se ukládají do stromu podle servisu a zakázky:

```
servisy/{servis_id}/zakazky/{cislo_zakazky}/  
├─ <kategorie>_<n>.jpg      – fotografie z příjmu (interiér, poškození, VIN...)  
├─ schema_poskozeni.png    – nákres poškození  
└─ protokol_{cislo}.pdf    – vygenerovaný protokol o příjmu
```

Aplikace soubory **nahrává** (foto, PDF, schéma) a později **čte** jejich veřejné odkazy, které ukládá do dokumentu zakázky ( `fotografie_urls` , `podpis_url` ). Zákaznický portál pak fotky a PDF zobrazuje z těchto odkazů.

## 6. Cloud Functions — serverová logika

Funkce běží v regionu `europa-west3`. Jsou jediným místem, kde žijí **tajné klíče** (Firebase Secrets) — v aplikaci nikdy nejsou.

| Funkce                         | Typ      | Co dělá / čte / zapisuje                                                                                                                                                                                       |
|--------------------------------|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>decodeVin</code>         | callable | Dekóduje VIN přes <b>Vincario</b> . Ověří uživatele → <code>servis_id</code> → plán. Čte/zapisuje <code>vin_cache</code> , rezervuje slot v <code>pouziti</code> (měsíční limit). Při cache-zásahu API nevolá. |
| <code>marketValueVin</code>    | callable | Zjistí tržní hodnotu vozu přes <b>Vincario</b> . Stejná logika, cache <code>value_cache</code> , limit <code>pouziti</code> .                                                                                  |
| <code>stkVin</code>            | callable | Načte STK a technická data z <b>api.dataovozidlech.cz</b> . Cache <code>stk_cache</code> na 24 h. Bez měsíčního limitu, jen ověření přihlášení.                                                                |
| <code>revenuecatWebhook</code> | HTTP     | Přijímá události o nákupu/obnově od <b>RevenueCat</b> a zapisuje důvěryhodný plán do <code>predplatne</code> . Chráněno tajným tokenem v hlavičce.                                                             |
| <code>deleteZamestnanec</code> | callable | Úplné odstranění člena týmu — smaže Auth účet i profil v <code>uzivatele</code> . Ověří, že volající je správce stejného servisu a nemaže sám sebe.                                                            |

**Tajné klíče (Firebase Secrets), jen na serveru:** `VINCARIO_API_KEY`, `VINCARIO_SECRET`, `DATAOVOZIDLECH_API_KEY`, `REVENUECAT_WEBHOOK_AUTH`.

**Proč přes server?** Vincario je placené za volání. Kdyby klíč byl v aplikaci, šel by z dekompilované aplikace vytáhnout a zneužít. Server navíc **tvrdě vynucuje měsíční limity** dle plánu a cachuje výsledky, takže stejný VIN se neplatí dvakrát.

## 7. Externí služby (mimo Firebase)

| Služba                        | Jak se volá          | Co táhneme / posíláme                                                                                 |
|-------------------------------|----------------------|-------------------------------------------------------------------------------------------------------|
| <b>Vincario</b>               | přes Cloud Functions | Posíláme VIN; čteme technické údaje vozidla a tržní hodnotu.                                          |
| <b>dataovozidlech.cz</b>      | přes Cloud Functions | Posíláme VIN; čteme STK a technická data.                                                             |
| <b>ARES</b> (ares.gov.cz)     | přímo z aplikace     | Posíláme IČO; čteme název firmy a adresu (předvyplnění zákazníka/servisu).                            |
| <b>ČNB</b> (api.cnb.cz)       | přímo z aplikace     | Čteme denní kurz EUR→CZK pro přepočet tržní hodnoty. Veřejné, bez klíče.                              |
| <b>RevenueCat</b>             | SDK + webhook        | Správa předplatného: nákupy, obnovy, nabídky. Plán pak potvrzuje webhook do <code>predplatne</code> . |
| <b>Google / Apple Sign-In</b> | SDK                  | Federované přihlášení (token identity). Žádná byznys data.                                            |
| <b>Google ML Kit</b> (OCR)    | na zařízení          | Rozpoznání VIN/SPZ z fotky. <b>Běží lokálně</b> — neodesílá fotku na server.                          |

## 8. Bezpečnostní model (shrnutí)

---

Detailní rozbor je v samostatném dokumentu „Bezpečnostní pravidla Firestore“. Klíčové zásady:

- **Vše zakázáno, dokud pravidlo výslovně nepovolí** (deny by default). Server-only kolekce nemají žádné povolení pro klienta.
- **Izolace servisů** — každý dotaz i zápis prochází kontrolou `servis_id` ; uživatel nevidí cizí servis.
- **Oprávnění modulů** — člen týmu má v profilu `prava` a aplikace mu zpřístupní jen povolené moduly.
- **Citlivá pole se nedají podvrhnout** — uživatel si nesmí přepsat `servis_id` , `role` ani `prava` ; placený plán zapisuje jen RevenueCat webhook.
- **Zákaznický portál** běží na **anonymním** přihlášení a vidí jen jednu zakázku přes její `portal_token` ; smí přidat zprávu a schválit/zamítnout nacenění, nic víc.

## 9. Příklady toku dat

### 9.1 Příjem vozidla (vytvoření zakázky)

1. Mechanik vyfotí vůz → ML Kit lokálně přečte VIN/SPZ (bez odeslání fotky).
2. Volitelně `decodeVin` / `stkVin` doplní technická data (přes funkce, s cache a limity).
3. IČO zákazníka se ověří v **ARES** (přímo).
4. Fotky, schéma a vygenerované PDF se nahrají do **Storage**.
5. Vznikne dokument v `zakazky` (+ aktualizace `vozidla` a `zakaznici`).
6. Při zapnutém odesílání e-mailu se založí dokument v `maily` → extension odešle protokol zákazníkovi.

### 9.2 VIN dekodér

Aplikace zavolá `decodeVin`. Funkce nejdřív zkusí `vin_cache`; při zásahu vrátí data zdarma. Jinak rezervuje slot v `pouziti` (kontrola limitu plánu), zavolá Vincario tajným klíčem, výsledek uloží do cache a vrátí. Historie se ukládá do `vin_skeny`.

### 9.3 Předplatné

Nákup probíhá přes RevenueCat SDK v aplikaci. Skutečný plán ale do `predplatne` zapisuje až **server** přes `revenuecatWebhook` — aplikace plán „povýšit“ nemůže. Limity API se pak odvozují z tohoto důvěryhodného plánu.

### 9.4 Zákaznický portál

Zákazník otevře odkaz `/zakazka/<token>` na Hostingu, aplikace ho přihlásí **anonymně** a podle `portal_token` načte jednu zakázku. Může číst stav a zprávy, přidat dotaz a schválit/zamítnout nacenění (subkolekce `zakaznik_zpravy`).

## 10. Co opouští zařízení — rychlý souhrn

| Data                                                | Kam jdou                                            | Poznámka                                   |
|-----------------------------------------------------|-----------------------------------------------------|--------------------------------------------|
| Přihlašovací identita                               | Firebase Auth / Google / Apple                      | Token, ne heslo v otevřené podobě.         |
| Byznys data (zakázky, vozidla, zákazníci, ceník...) | Firestore                                           | Izolováno per <code>servis_id</code> .     |
| Fotky, PDF, podpis                                  | Cloud Storage                                       | Odkazy uložené u zakázky.                  |
| VIN, IČO                                            | Vincario/dataovozidlech (přes server), ARES (přímo) | VIN přes funkce; klíče na serveru.         |
| Fotka vozidla pro OCR                               | nikam — zpracuje se na zařízení                     | ML Kit běží lokálně.                       |
| Údaje o pádu aplikace                               | Crashlytics                                         | Technická diagnostika, ne byznys obsah.    |
| E-mail zákazníkovi                                  | Trigger Email extension                             | Spouští se zápisem do <code>maily</code> . |